

AGEX Security Architecture

1. 문서 개요

1.1 문서 목적

본 문서는 AGEX Security Architecture의 원칙, 보안 경계, Identity, Authentication, Authorization, Tenant Isolation, Secret, Data Protection, Runtime Security, Agent Security, Workflow Security, Plugin Security, Model Security, Knowledge-Memory Security, Supply Chain Security, Audit, Incident Response 및 Security Governance 기준을 정의한다.

AGEX는 AI Agent, Workflow, Plugin, Model, Knowledge, Memory 및 외부 시스템이 지속적으로 상호작용하는 AI Operating System이므로 일반적인 Web Application 수준의 보안 구조만으로는 충분하지 않다.

AGEX Security Architecture는 다음을 동시에 통제해야 한다.

- 사용자
- 관리자
- Service Identity
- Agent
- Workflow
- Plugin
- Model Provider
- External API
- Knowledge Source
- Memory
- Runtime Worker
- Package
- Marketplace Publisher
- Tenant
- Infrastructure Provider

본 문서는 AGEX 전체 보안 설계의 최상위 기술 기준으로 사용한다.

1.2 적용 범위

본 문서는 다음 보안 영역을 포함한다.

- Security Principles
- Trust Boundary
- Identity Architecture
- Authentication
- Authorization
- Policy Enforcement
- Tenant Isolation
- Agent Security
- Workflow Security
- Runtime Security
- Plugin Security
- Model Security
- Knowledge Security
- Memory Security
- Data Security
- Encryption
- Key Management
- Secret Management
- Network Security
- API Security
- Event Security
- Marketplace Security
- Supply Chain Security

- Administrative Security
- Audit
- Monitoring
- Threat Detection
- Incident Response
- Security Testing
- Security Governance

1.3 Security Architecture의 공식 정의

AGEX Security Architecture는 모든 Identity, Resource, Execution, Data 및 Extension을 기본적으로 신뢰하지 않고, 명시적인 인증·권한·정책·격리·검증을 통과한 경우에만 접근과 실행을 허용하는 Zero Trust 기반 보안 구조이다.

2. 보안 목표

AGEX Security Architecture는 다음 목표를 충족해야 한다.

2.1 기밀성

허가되지 않은 Principal, Agent, Plugin, Model 또는 Tenant가 데이터에 접근할 수 없어야 한다.

2.2 무결성

Resource Definition, Policy, Execution State, Package 및 Audit Record가 임의로 변경되지 않아야 한다.

2.3 가용성

특정 Tenant, Agent, Plugin 또는 외부 Provider의 장애나 공격이 Platform 전체 가용성으로 확산되지 않아야 한다.

2.4 격리성

Tenant, Runtime, Plugin, Execution 및 Secret이 상호 격리되어야 한다.

2.5 최소 권한

모든 Identity에는 업무 수행에 필요한 최소 권한만 부여한다.

2.6 통제된 자율성

Agent의 자율적 판단이 보안 권한 확대나 Policy 우회로 이어질 수 없어야 한다.

2.7 추적 가능성

중요한 모든 보안 관련 행위는 Audit할 수 있어야 한다.

2.8 복구 가능성

보안 사고 발생 시 해당 Resource, Identity, Package 또는 Tenant를 신속하게 차단하고 복구할 수 있어야 한다.

2.9 공급망 신뢰성

Plugin, SDK, Runtime Image 및 Marketplace Package의 출처와 무결성을 확인할 수 있어야 한다.

2.10 데이터 주권

Tenant 정책과 데이터 등급에 따라 저장·처리·외부 전송 위치를 통제할 수 있어야 한다.

3. 핵심 보안 원칙

AGEX는 다음 보안 원칙을 최상위 기준으로 적용한다.

- Security by Design
- Zero Trust
- Default Deny
- Least Privilege
- Explicit Trust
- Defense in Depth
- Tenant Isolation
- Identity Everywhere
- Policy Before Execution
- Secret Never in Plain Context
- Secure by Default

- Immutable Audit
 - Signed Artifact
 - Isolated Extension
 - Bounded Autonomous Action
 - Data Minimization
 - Purpose Limitation
 - Fail Closed
 - Continuous Verification
 - Security Observable by Default
-

4. Zero Trust Architecture

4.1 기본 원칙

AGEX 내부 Network 또는 내부 Service라는 이유만으로 신뢰하지 않는다.

다음 대상은 모두 기본적으로 신뢰하지 않는다.

- User
- Administrator
- Service
- Agent
- Workflow
- Plugin
- Model
- External API
- Runtime Worker
- Marketplace Package
- Event

- Knowledge Source
- Memory Content
- Generated Code
- Internal Network Request

4.2 Zero Trust 요청 흐름

Request / Action

- Identity Verification
- Tenant Resolution
- Authentication
- Authorization
- Resource Scope
- Policy Evaluation
- Risk Evaluation
- Data Classification
- Runtime Enforcement
- Audit / Trace
- Execution

4.3 지속 검증

실행 시작 시 한 번 검증했다고 실행 종료까지 무조건 신뢰하지 않는다.

다음 상황에서는 재검증할 수 있어야 한다.

- 장기 실행
- 정책 변경
- Permission 변경
- Tenant Suspension
- Credential Rotation

- 보안 경보
 - 위험도 상승
 - 외부 Side Effect 직전
-

5. Security Trust Boundary

AGEX의 주요 보안 경계는 다음과 같다.

1. User ↔ Platform
2. Application Layer ↔ Platform API
3. Tenant ↔ Tenant
4. Agent ↔ Runtime
5. Agent ↔ Tool/Plugin
6. Workflow ↔ Child Execution
7. Runtime ↔ External Provider
8. Plugin ↔ External Network
9. Runtime Worker ↔ Control Plane
10. Platform ↔ Infrastructure
11. Marketplace ↔ Package
12. Knowledge Source ↔ Knowledge Engine
13. Model ↔ Context/Data
14. Administrator ↔ Privileged Control Plane

각 Trust Boundary에는 독립적인 인증, 권한, Schema Validation 및 Audit를 적용한다.

6. Identity Architecture

6.1 Identity 유형

AGEX는 최소한 다음 Identity 유형을 구분한다.

- Human Identity
- Service Identity
- Workload Identity
- Agent Identity
- Execution Identity
- Plugin Identity
- Publisher Identity
- Administrator Identity

6.2 Identity 공통 속성

- Identity ID
- Identity Type
- Tenant ID
- Status
- Roles
- Attributes
- Authentication Method
- Trust Level
- Created At
- Last Verified At

6.3 Identity 공유 금지

하나의 Credential을 여러 독립 Service나 Agent에서 공유하는 것을 최소화한다.

6.4 Agent Identity

Agent Definition Identity와 Runtime Execution Identity를 구분한다.

Agent가 실행될 때는 해당 Execution에 필요한 최소 Scope의 Runtime Identity를 사용할 수 있다.

7. Authentication Architecture

7.1 지원 방식

배포 구조에 따라 다음 인증 방식을 지원할 수 있다.

- OpenID Connect
- OAuth 2.x
- SAML 연계
- API Credential
- Mutual TLS
- Workload Identity
- Service Token
- Hardware-backed Authentication

7.2 사용자 인증

사용자 인증은 가능한 경우 외부 또는 통합 Identity Provider와 연계한다.

7.3 MFA

다음 행위에는 Multi-Factor Authentication 또는 Step-Up Authentication을 요구할 수 있다.

- Tenant 관리자 기능
- Permission 확대
- Secret 변경
- Package Block 해제
- Security Policy 변경
- 강제 Execution 종료
- Bulk Delete
- 중요 데이터 Export

7.4 Session

Session은 다음을 관리해야 한다.

- Expiration
 - Idle Timeout
 - Revocation
 - Device/Context Risk
 - Reauthentication
-

8. Service-to-Service Authentication

8.1 원칙

내부 Service 호출도 인증해야 한다.

8.2 Service Identity

각 Service 또는 Workload는 독립 Identity를 가져야 한다.

8.3 단기 Credential

가능하면 Short-Lived Credential을 사용한다.

8.4 Mutual Authentication

고보안 내부 구간에서는 mTLS 또는 이에 준하는 양방향 인증을 적용할 수 있다.

8.5 Static Secret 최소화

장기 고정 Service Password 사용을 최소화한다.

9. Authorization Architecture

9.1 권한 모델

AGEX는 다음을 결합한 Authorization을 지원해야 한다.

- RBAC
- ABAC

- Resource-Based Access
- Policy-Based Access
- Tenant Scope
- Environment Scope
- Risk Context

9.2 권한 평가식

개념적으로 실제 Permission은 다음 요소를 종합한다.

Identity Role

$\cap$

Identity Attributes

$\cap$

Tenant Scope

$\cap$

Resource Permission

$\cap$

Policy

$\cap$

Environment

$\cap$

Execution Constraint

9.3 Default Deny

명시적으로 허용되지 않은 Action은 거부한다.

9.4 권한 캐시

Authorization 결과를 Cache할 수 있지만 Permission 변경과 Revocation이 신속히 반영되어야 한다.

10. RBAC

10.1 목적

일반적인 사용자·관리자 기능의 권한을 Role로 관리한다.

10.2 Role 예시

- Platform Administrator
- Tenant Administrator
- Developer
- Operator
- Auditor
- End User

10.3 Role의 한계

Role만으로 Agent, Plugin, Data Classification 및 동적 Context 권한을 모두 결정하지 않는다.

10.4 과도한 Super Role 방지

모든 Resource에 무제한 접근하는 범용 Role을 최소화한다.

11. ABAC

11.1 평가 Attribute

- Identity Type
- Tenant
- Department/Group
- Resource Owner
- Resource Classification
- Environment

- Time
- Region
- Risk
- Execution Type

11.2 사용 목적

고정 Role만으로 표현하기 어려운 세밀한 정책에 사용한다.

11.3 예시

Allow:

Principal = Agent

AND

Tenant = Resource Tenant

AND

Action = knowledge.read

AND

Resource Classification <= Agent Allowed Classification

12. Policy Decision Architecture

12.1 구성요소

- Policy Administration Point
- Policy Decision Point
- Policy Enforcement Point
- Policy Information Point

12.2 Policy Enforcement Point

다음 영역에서 정책을 적용한다.

- API Gateway

- Core Service
- Runtime
- Agent Action
- Plugin Gateway
- Knowledge Retrieval
- Memory Retrieval
- Marketplace Installation
- Model Gateway

12.3 Policy 결과

- Permit
- Deny
- Permit With Obligation
- Require Approval
- Require Reauthentication
- Indeterminate

12.4 Policy 실패

결정할 수 없는 경우 기본적으로 Deny한다.

13. Tenant Isolation

13.1 기본 원칙

Tenant는 모든 AGEX Resource의 최상위 보안 Scope이다.

13.2 Tenant ID 적용 대상

- Resource
- Execution
- Task

- Event
- Knowledge
- Memory
- Plugin Installation
- Secret
- Artifact
- Audit
- Usage

13.3 Isolation 방식

배포 위험 수준에 따라 다음을 조합할 수 있다.

- Logical Isolation
- Namespace Isolation
- Database Partition
- Schema Isolation
- Dedicated Database
- Encryption Key Isolation
- Worker Pool Isolation
- Network Isolation
- Dedicated Runtime

13.4 Cross-Tenant 접근

일반 AGEX Resource에서는 기본적으로 금지한다.

13.5 Platform Administrator

Platform 관리자라고 해서 Tenant Data에 자동 접근할 수 있도록 하지 않는다.

필요 시 별도 권한, 목적 및 Audit를 요구한다.

14. Tenant Context Enforcement

14.1 요청

Tenant Resource 요청에는 Tenant Context가 존재해야 한다.

14.2 Token과 Request 불일치

Identity Token의 Tenant와 요청 Scope가 불일치하면 거부한다.

14.3 내부 호출

Service-to-Service 호출에도 Tenant Context를 전달한다.

14.4 Async Task

Queue Message에도 Tenant Context를 포함한다.

14.5 Data Layer

Repository 또는 Query 레벨에서도 Tenant Filter가 누락되지 않도록 강제한다.

15. Agent Security

15.1 Agent는 신뢰 경계 내부가 아님

Agent는 AI 기반으로 동작하므로 그 출력과 행동은 기본적으로 검증 대상이다.

15.2 Agent가 할 수 없는 행위

- 자신의 Permission 수정
- Tenant Scope 변경
- Policy 수정
- Secret Store 직접 조회
- 감사 기능 비활성화
- 승인 우회
- Runtime Security 설정 변경
- 무제한 Child Agent 생성

15.3 Tool Call

Agent가 생성한 Tool Call은 Runtime에서 다시 검증한다.

15.4 Model 출력

Model이 "이 Action을 수행하라"고 생성했다고 실행 권한이 생기는 것은 아니다.

15.5 Agent Context

보안 Policy와 외부 Content를 명확히 분리한다.

16. Prompt Injection Security

16.1 위험

외부 문서, Web Content, Plugin Response, User Input 또는 Memory 안에 악의적 지시가 포함될 수 있다.

16.2 기본 방어

- System Instruction과 Data 분리
- Tool Permission 재검증
- 외부 Content를 Untrusted로 표시
- Context Source Metadata 유지
- High-Risk Action 추가 확인
- Data Exfiltration 검사

16.3 외부 지시의 권한 상승 금지

Retrieved Knowledge의 텍스트가 Agent Permission이나 Policy를 변경할 수 없다.

16.4 Tool Injection

Tool 이름이나 Parameter를 자연어 그대로 실행하지 않고 등록된 Tool Contract로 Validation한다.

17. Agent Data Exfiltration Protection

다음 단계에서 Data Policy를 검증해야 한다.

Agent Action

→ Destination 확인

→ Data Classification

→ Allowed Provider

→ Allowed Region

→ Allowed Fields

→ Permission

→ Execute

17.1 민감정보 Redaction

외부 Model이나 Plugin으로 보내기 전에 필요에 따라 Masking 또는 Field Removal을 적용한다.

17.2 목적 외 전송

Agent가 Goal과 관계없는 데이터를 외부 Tool에 포함하지 않도록 제한한다.

18. Workflow Security

18.1 Workflow는 권한 상승 수단이 아님

Workflow가 보유한 전체 권한을 각 Step에 자동 상속하지 않는다.

18.2 Step-Level Authorization

각 Step 실행 전에 개별 권한과 Policy를 평가한다.

18.3 Dynamic Workflow

Agent가 생성한 동적 Step도 동일한 Security Validation을 통과해야 한다.

18.4 Approval Step

중요 Action에 대한 승인 정보는 변경 불가능한 방식으로 Action과 연결해야 한다.

18.5 Workflow Version

실행 중 Workflow Definition을 변경하지 않는다.

19. Runtime Security

19.1 Runtime은 보안 집행점

Runtime은 최종 실행 직전의 Security Enforcement Point이다.

19.2 Runtime Execution Token

각 Execution은 제한된 범위의 Execution Token 또는 Security Context를 가질 수 있다.

포함 가능 정보:

- Execution ID
- Tenant ID
- Principal
- Allowed Resource
- Allowed Actions
- Expiration
- Policy Snapshot
- Constraints

19.3 Worker 신뢰 금지

Worker가 Task를 수신했다고 모든 내부 자원 접근 권한을 가져서는 안 된다.

19.4 Worker Identity

Worker는 Workload Identity를 사용한다.

19.5 Runtime Privilege

Task에 필요한 최소 권한만 부여한다.

20. Runtime Isolation

20.1 격리 대상

- Execution
- Tenant

- Plugin
- Generated Code
- Untrusted Package
- High-Risk Action

20.2 격리 방식

- Process
- Container
- Namespace
- MicroVM
- Sandbox
- Dedicated Worker Pool

20.3 High-Risk Execution

Critical 수준의 실행은 별도 Worker Pool이나 강화된 Sandbox에서 수행할 수 있다.

20.4 Host 접근

Runtime Task가 Host OS와 Infrastructure Credential에 직접 접근하지 않도록 한다.

21. Sandbox Security

21.1 Default Restriction

Sandbox 기본값은 다음을 차단한다.

- Host File System
- Privileged Syscall
- Arbitrary Network
- Core Database
- Secret Store
- Other Tenant

- Other Execution Memory

21.2 Resource Limit

- CPU
- Memory
- Disk
- Network
- Process
- Execution Time

21.3 Ephemeral Environment

가능한 경우 Task 종료 후 Sandbox를 폐기한다.

21.4 Persistent Artifact

필요한 결과만 검증 후 Artifact Store로 이동한다.

22. Plugin Security

22.1 Zero Trust Plugin

Marketplace에서 검증된 Plugin도 Runtime 시 다시 검증한다.

22.2 Plugin Permission

Plugin은 Manifest에 선언한 Permission 범위만 사용할 수 있다.

22.3 Credential

Plugin에 장기 Credential 원문을 전달하지 않는 것을 원칙으로 한다.

22.4 Network

Manifest와 Tenant Policy에 허용된 Endpoint만 접근한다.

22.5 Hidden Network 금지

Plugin이 실행 중 선언되지 않은 외부 Endpoint로 접속하면 정책 위반으로 처리한다.

23. Plugin Output Security

23.1 외부 응답은 Untrusted

Plugin Output은 신뢰할 수 없는 외부 입력으로 취급한다.

23.2 검증

- Output Schema
- Size
- Content Type
- Malware
- Sensitive Data
- Prompt Injection Pattern

23.3 Agent 전달

Plugin 응답을 System Instruction과 구분하여 전달한다.

24. Model Security Architecture

24.1 Model은 Security Authority가 아님

Model은 다음을 최종 결정할 수 없다.

- Permission
- Authentication
- Policy
- Tenant
- Secret Access
- Administrator Action

24.2 Model Gateway

모든 공식 Model 호출은 Model Gateway를 통해야 한다.

24.3 Model Provider Policy

Provider 선택 시 다음을 고려한다.

- Data Classification
- Region
- Retention
- Training Policy
- Security Level
- Tenant Allowlist
- Contract Status

24.4 Aggregator Provider

중계 Provider는 직접 Provider와 별도 Trust Level을 가져야 한다.

24.5 Model Fallback

Security 또는 Data Policy를 위반하는 Provider로 Fallback하지 않는다.

25. Model Data Protection

25.1 전송 최소화

Model Context에는 Task 수행에 필요한 최소 데이터만 포함한다.

25.2 Secret

Credential 원문은 Model Context에 포함하지 않는다.

25.3 Sensitive Data

필요한 경우 다음을 수행한다.

- Masking
- Tokenization
- Redaction
- Field Removal
- Private Provider Routing

25.4 Prompt Logging

Prompt와 Response 전체를 일반 운영 Log에 저장하지 않는다.

26. Model Provider Trust Level

Provider는 다음과 같은 Trust Category를 가질 수 있다.

- Private
- Direct Approved
- Enterprise Approved
- Aggregator
- Restricted
- Blocked

26.1 Data Policy 연계

예:

PUBLIC

→ Approved / Aggregator 가능

INTERNAL

→ Tenant Policy에 따라 가능

CONFIDENTIAL

→ Direct Approved 또는 Private

RESTRICTED

→ Private / Dedicated Provider

실제 Classification 정책은 Tenant 및 배포 환경에서 정의한다.

27. Knowledge Security

27.1 Retrieval Before Context

Permission 검증은 Knowledge를 Model Context에 넣기 전에 수행한다.

27.2 Source Classification

Source의 보안 등급을 Chunk, Index 및 Retrieval Result에도 유지한다.

27.3 Vector Store

Vector Index가 Tenant 보안 경계를 우회할 수 없도록 한다.

27.4 Source Permission Sync

원본 Source 권한이 변경되면 Retrieval 권한도 신속하게 반영해야 한다.

27.5 Malicious Document

Knowledge 파일 자체에 대한 Malware와 Injection 검사를 수행할 수 있다.

28. Memory Security

28.1 최소 저장

필요한 정보만 Memory에 저장한다.

28.2 User Memory

User Memory는 다른 사용자 또는 다른 Tenant가 조회할 수 없다.

28.3 Secret Memory 금지

Credential 원문을 일반 Memory에 저장하지 않는다.

28.4 Memory Injection

Memory Content가 System Policy보다 높은 우선순위를 가질 수 없다.

28.5 Deletion

삭제 요청은 Derived Index와 Cache에도 전파되어야 한다.

29. Data Classification Architecture

29.1 목적

모든 데이터는 보안 및 처리 정책을 결정하기 위한 Classification을 가질 수 있다.

29.2 권장 범주

AGEX Core는 범용적으로 다음과 같은 등급 구조를 지원할 수 있다.

- PUBLIC
- INTERNAL
- CONFIDENTIAL
- RESTRICTED

실제 명칭은 Tenant Policy에서 확장할 수 있다.

29.3 Classification 적용 대상

- Document
- Knowledge
- Memory
- Artifact
- API Payload
- Event
- Plugin Result
- Model Context
- Export

29.4 상속

Derived Data는 원본보다 낮은 Classification을 자동으로 부여받지 않는다.

30. Data Handling Policy

Classification에 따라 다음을 통제한다.

- 저장 위치
- 암호화
- 외부 전송
- Model Provider
- Plugin 사용
- Region
- Retention
- Audit
- Export
- Cache

30.1 Policy 평가

Data Handling은 Agent의 판단이 아니라 Policy Engine이 결정한다.

31. Encryption in Transit

31.1 외부 통신

모든 Public API와 외부 Connector는 암호화된 전송을 사용한다.

31.2 내부 통신

Service-to-Service 통신도 민감도에 따라 TLS/mTLS를 적용한다.

31.3 약한 Protocol

취약하거나 지원 종료된 Protocol을 사용하지 않는다.

32. Encryption at Rest

다음 저장 영역은 기본적으로 암호화를 지원해야 한다.

- Database
- Object Storage

- Backup
- Knowledge
- Memory
- Artifact
- Secret
- Audit Storage

32.1 Tenant Key

필요한 환경에서는 Tenant별 Encryption Key를 지원할 수 있다.

32.2 Key Rotation

Encryption Key Rotation을 지원해야 한다.

33. Key Management

33.1 Key 유형

- Data Encryption Key
- Key Encryption Key
- Signing Key
- TLS Key
- Package Signing Key
- Webhook Signing Key

33.2 KMS/HSM

고보안 환경에서는 KMS 또는 HSM과 연계할 수 있다.

33.3 Key 접근

일반 Application이나 Agent가 Master Key에 접근할 수 없어야 한다.

33.4 Key Rotation

Rotation 시 기존 데이터 복호화 가능성을 안전하게 유지해야 한다.

34. Secret Management

34.1 Secret 대상

- API Key
- Password
- Token
- Client Secret
- Private Key
- Certificate
- Refresh Token

34.2 저장

Secret은 전용 Secret Store에 저장한다.

34.3 참조

Resource에는 Secret 값이 아니라 Secret Reference를 저장한다.

34.4 Runtime Injection

실행 시 필요한 범위로만 전달한다.

34.5 Log 금지

Secret을 Log, Trace, Event 또는 Audit Payload에 원문 기록하지 않는다.

35. Secret Rotation

35.1 지원 대상

- Provider Credential
- Plugin Credential
- Signing Key
- Service Credential

35.2 Rotation 방식

Zero-Downtime Rotation을 지원할 수 있어야 한다.

35.3 실패

Rotation 실패 시 이전 Credential을 무기한 유지하지 않도록 Alert와 만료 정책을 적용한다.

35.4 Compromise

Credential 유출 의심 시 즉시 Revocation을 지원한다.

36. API Security

36.1 API Gateway Security

다음 기능을 적용한다.

- TLS
- Authentication
- Rate Limit
- Request Size
- Threat Filtering
- Schema Validation
- Tenant Resolution
- Request ID

36.2 Object-Level Authorization

ID만 알고 있다고 Resource에 접근할 수 없어야 한다.

36.3 Mass Assignment

API Input에서 변경 가능한 Field를 명시적으로 제한한다.

36.4 Injection

SQL, Command, Template 및 기타 Injection 방어를 적용한다.

36.5 Admin API

관리 API는 별도의 Permission과 강화된 인증을 요구한다.

37. Network Security

37.1 Network Segmentation

다음 영역을 논리적 또는 물리적으로 분리할 수 있다.

- Public Edge
- API Layer
- Control Plane
- Runtime
- Sandbox
- Data Layer
- Management Plane

37.2 East-West Traffic

내부 Service 간 통신도 보안 정책을 적용한다.

37.3 Egress Control

특히 Runtime과 Plugin 환경의 외부 통신은 Allowlist 기반으로 통제한다.

37.4 Ingress

필요한 Endpoint만 외부에 노출한다.

38. Private Connectivity

Enterprise 배포에서는 다음을 지원할 수 있다.

- Private Network
- VPN
- Private Endpoint

- VPC/VNet Peering
- Dedicated Link

38.1 Public 인터넷 비활성

필요한 Tenant는 Public API 노출 없이 운영할 수 있도록 설계할 수 있다.

39. Event Security

39.1 Event Identity

Event는 Source와 Tenant를 식별할 수 있어야 한다.

39.2 Event Schema

Schema 검증 없는 Event를 Domain State Change에 사용하지 않는다.

39.3 Event Spoofing

Reserved System Event를 일반 Client가 발행하지 못하게 한다.

39.4 Replay

Event ID와 Idempotency를 통해 Replay Attack을 방어한다.

39.5 민감 Payload

Event에 Secret이나 불필요한 민감 데이터를 포함하지 않는다.

40. Webhook Security

40.1 Outbound Webhook

- Signature
- Timestamp
- Delivery ID
- Retry Limit

40.2 Inbound Webhook

- Signature Verification

- Source Validation
- Nonce
- Replay Prevention
- Tenant Mapping

40.3 SSRF

Webhook Endpoint 설정 시 내부 Network 대상 우회 접근을 방지한다.

41. SSRF Protection

41.1 주요 위험 영역

- Plugin
- Connector
- Webhook
- URL Fetch
- Dynamic External Endpoint

41.2 방어

- Allowlist
- DNS Validation
- IP Range Block
- Redirect Validation
- Metadata Endpoint Block
- Proxy Enforcement

41.3 Cloud Metadata

Runtime이나 Plugin이 Cloud Metadata Endpoint에 접근하지 못하도록 차단해야 한다.

42. File Security

42.1 Upload

파일 Upload 시 다음을 검증한다.

- Size
- MIME Type
- Extension
- Malware
- Archive Bomb
- Embedded Script

42.2 저장

원본 파일과 처리 파일을 격리할 수 있다.

42.3 실행

Upload 파일을 자동 실행하지 않는다.

42.4 다운로드

Tenant와 Permission을 다시 검증한다.

43. Artifact Security

43.1 Artifact 정보

Artifact는 다음 Metadata를 가질 수 있다.

- Owner
- Tenant
- Classification
- Checksum
- Content Type
- Expiration
- Encryption

43.2 Signed URL

임시 다운로드 링크를 사용하는 경우 짧은 만료시간과 최소 권한을 적용한다.

43.3 Public Artifact

명시적 Publish가 없는 Artifact는 Public으로 노출하지 않는다.

44. Marketplace Security

44.1 핵심 검증

- Publisher Identity
- Signature
- Artifact Integrity
- Dependency
- Vulnerability
- Malware
- Permission
- Network
- Data Handling

44.2 Trust Level

Marketplace Trust Level은 Runtime 격리 정책과 연결되어야 한다.

44.3 Block

Critical 사고가 발생한 Package는 기존 Installation의 신규 실행까지 차단할 수 있다.

44.4 Silent Update 금지

Permission 또는 Security 의미가 변경되는 Version을 자동 적용하지 않는다.

45. Supply Chain Security

45.1 대상

- SDK
- Runtime Image
- Plugin Package
- Marketplace Package
- Build Dependency
- Container
- Binary
- External Library

45.2 요구사항

- Artifact Signing
- Checksum
- Dependency Inventory
- Vulnerability Scan
- Build Provenance
- Trusted Registry

45.3 Dependency Pinning

Production Artifact는 가능한 한 Dependency Version을 고정한다.

45.4 Build System

Build Environment 자체도 접근 권한과 Secret을 제한한다.

46. SBOM

46.1 목적

Software Bill of Materials를 생성하여 사용 Dependency를 추적한다.

46.2 대상

- Core Service

- Runtime Image
- Plugin Package
- SDK Release

46.3 취약점 대응

신규 취약점 발견 시 영향을 받는 Artifact와 Version을 빠르게 식별할 수 있어야 한다.

47. Container and Runtime Image Security

47.1 이미지 검증

Production Image는 다음을 검증한다.

- Signature
- Provenance
- Vulnerability
- Base Image
- Dependency

47.2 Root 실행

가능하면 Non-Root로 실행한다.

47.3 Read-Only

가능한 영역은 Read-Only File System을 사용한다.

47.4 Privileged Container

기본적으로 금지한다.

48. Infrastructure Security

48.1 IaC

Infrastructure Configuration은 선언적 방식으로 관리하는 것을 권장한다.

48.2 관리자 접근

Infrastructure 관리자 접근은 다음을 적용할 수 있다.

- MFA
- JIT Access
- Bastion
- Session Recording
- Audit

48.3 Production 직접 변경

운영 인프라의 수동 변경을 최소화한다.

48.4 Drift Detection

정의된 Infrastructure와 실제 환경 차이를 탐지할 수 있어야 한다.

49. Database Security

49.1 접근

Application은 필요한 Database Role만 사용한다.

49.2 Shared DBA Credential

모든 Service가 동일 관리자 계정을 사용하지 않는다.

49.3 Network

Database는 일반 Public Internet에 직접 노출하지 않는다.

49.4 Query Logging

민감 데이터가 Query Log에 과도하게 기록되지 않도록 한다.

49.5 Backup

Backup도 암호화와 접근 제어를 적용한다.

50. Cache Security

50.1 Tenant Context

Cache Key에는 필요한 Tenant Scope를 포함한다.

50.2 민감정보

Secret이나 고위험 Sensitive Data를 일반 Cache에 저장하지 않는 것을 원칙으로 한다.

50.3 Invalidation

Permission이나 Policy 변경 시 관련 Cache를 무효화해야 한다.

51. Logging Security

51.1 Log 금지 항목

- Password
- API Key
- Access Token
- Refresh Token
- Private Key
- 전체 민감 Document
- 전체 User Memory

51.2 Redaction

중앙 Logging 전에 민감정보 Masking을 적용한다.

51.3 접근

Production Log 접근도 Role과 Tenant Scope를 적용한다.

51.4 보존

Log Retention을 별도로 정의한다.

52. Audit Architecture

52.1 Audit 대상

- Authentication

- Permission Change
- Policy Change
- Tenant Change
- Secret Access
- Resource Publish
- Package Install
- High-Risk Plugin Action
- Memory Delete
- Forced Termination
- Administrator Override
- Security Incident Action

52.2 Audit Record

- Audit ID
- Timestamp
- Tenant
- Principal
- Action
- Resource
- Result
- Reason
- Source
- Request ID
- Trace ID

52.3 불변성

Audit Record는 일반 관리자도 임의 수정할 수 없어야 한다.

52.4 Audit Integrity

다음 방식을 사용할 수 있다.

- Append-Only Store
 - Hash Chain
 - Digital Signature
 - External Immutable Archive
-

53. Chain-of-Thought Security

53.1 원칙

Raw Chain-of-Thought를 Security Audit이나 Observability를 위해 필수 저장하지 않는다.

53.2 대신 저장할 정보

- Input Reference
- Plan
- Selected Action
- Tool Calls
- Knowledge References
- Policy Decisions
- Output
- Evaluation
- Failure Reason

53.3 이유

민감한 내부 추론 정보의 불필요한 보존을 방지하고, 운영상 필요한 추적성은 구조화된 기록으로 제공한다.

54. Security Logging and Detection

54.1 보안 Event

다음 Event를 탐지할 수 있어야 한다.

- Repeated Authentication Failure
- Permission Denial Spike
- Cross-Tenant Access Attempt
- Secret Access Anomaly
- Unusual Plugin Network
- Agent Tool Abuse
- Excessive Data Export
- Suspicious Package
- Runtime Escape Attempt

54.2 Security Event Severity

- Informational
- Low
- Medium
- High
- Critical

54.3 자동 Action

Critical Event에 대해 다음을 수행할 수 있다.

- Execution Termination
- Identity Revocation
- Plugin Suspension
- Package Block
- Tenant Isolation
- Credential Rotation

55. Threat Detection

55.1 Behaviour 기반 탐지

단순 Signature 외에 행동 패턴도 사용할 수 있다.

55.2 탐지 대상

- 비정상 API 호출량
- 권한 탐색
- 대량 Resource 조회
- 비정상 Model Context 크기
- External Endpoint 증가
- 반복된 Policy Denial
- Suspicious Agent Delegation

55.3 False Positive

자동 차단 정책은 위험 수준과 서비스 영향도를 고려한다.

56. Security Incident Response

56.1 기본 단계

Detect

→ Triage

→ Contain

→ Investigate

→ Eradicate

→ Recover

→ Review

56.2 Containment 수단

- Identity Revoke
- Secret Rotate
- Execution Kill
- Plugin Suspend
- Package Block
- Tenant Isolate
- Endpoint Block
- Runtime Pool Drain

56.3 Evidence

Incident 조사에 필요한 Audit, Trace, Security Event를 보존한다.

56.4 복구

복구 후 정상 Resource와 Credential을 재검증한다.

57. Security Kill Switch

57.1 적용 대상

- Agent
- Workflow
- Plugin
- Package
- Model Provider
- Runtime Pool
- Tenant

57.2 동작

Kill Switch는 신규 실행 차단과 기존 실행 중단 여부를 구분할 수 있어야 한다.

57.3 권한

Kill Switch 사용은 높은 관리자 권한과 Audit를 요구한다.

57.4 긴급 보안 예외

Critical 사고에서는 일반 Approval Workflow보다 긴급 차단이 우선할 수 있다.

58. Administrative Security

58.1 Privileged Account

관리자 계정을 일반 업무 계정과 구분할 수 있다.

58.2 Just-In-Time Access

고위험 운영 권한은 필요한 시간에만 부여할 수 있다.

58.3 Break Glass

비상 관리자 계정을 제공할 수 있으나 사용 시 강화된 Audit와 알림을 수행해야 한다.

58.4 관리자 본인 행위

관리자도 자신의 보안 Audit를 삭제하거나 무효화할 수 없어야 한다.

59. Separation of Duties

다음 역할은 필요에 따라 분리한다.

- Developer
- Publisher
- Security Reviewer
- Production Approver
- Platform Operator
- Auditor
- Billing Administrator

59.1 예

Plugin 개발자가 자신이 개발한 Critical Plugin을 단독 검증하고 Production에 Publish하

는 구조를 제한할 수 있다.

60. Data Retention Security

60.1 Resource별 정책

- Log
- Audit
- Knowledge
- Memory
- Artifact
- Execution
- Security Event

각각 별도 Retention 정책을 정의한다.

60.2 삭제

Retention 종료 후 안전한 삭제 절차를 지원한다.

60.3 Backup

원본 삭제 후 Backup에서 무기한 복원되지 않도록 Backup Retention도 관리한다.

61. Secure Deletion

61.1 논리 삭제

사용자 접근을 먼저 차단한다.

61.2 Derived Data

삭제 시 다음도 처리한다.

- Cache
- Search Index
- Vector Index

- Summary
- Read Model

61.3 Immutable Audit

삭제 행위 자체에 대한 최소 Audit Record는 별도로 유지할 수 있다.

62. Data Export Security

62.1 대량 Export

다음 통제를 적용할 수 있다.

- Explicit Permission
- Approval
- Step-Up Authentication
- Rate Limit
- Watermark/Metadata
- Audit
- Expiration

62.2 Export Artifact

생성된 Export 파일은 제한된 시간 동안만 접근 가능하도록 설정할 수 있다.

63. Data Residency

63.1 Tenant Policy

Tenant는 데이터 저장·처리 허용 Region을 설정할 수 있어야 한다.

63.2 적용 대상

- Storage
- Model
- Plugin

- Backup
- Runtime
- Knowledge Index

63.3 Policy 위반 Fallback 금지

가용성 문제를 이유로 허용되지 않은 Region으로 데이터를 자동 이동하지 않는다.

64. Environment Security

64.1 Environment 구분

- Development
- Testing
- Staging
- Production

64.2 Production Data

Production 민감 데이터를 개발 환경으로 무단 복사하지 않는다.

64.3 Credential 분리

환경별 Credential을 분리한다.

64.4 권한 분리

Development 관리자 권한이 Production으로 자동 이어지지 않아야 한다.

65. CI/CD Security

65.1 Pipeline Identity

CI/CD도 독립 Workload Identity를 사용한다.

65.2 Secret

Build Log에 Secret이 노출되지 않도록 한다.

65.3 Approval

Production Deploy에는 정책에 따라 승인 단계를 둘 수 있다.

65.4 Artifact Promotion

동일 검증 Artifact를 Environment 간 Promotion하는 방식을 권장한다.

66. Code Security

66.1 Secure Development

개발 단계에서 다음을 적용한다.

- Static Analysis
- Dependency Scan
- Secret Scan
- Code Review
- Security Test

66.2 Generated Code

AI가 생성한 코드도 다른 코드와 동일하게 검증한다.

66.3 직접 Production 적용 금지

검증되지 않은 Model-generated code를 Production Runtime에 직접 배포하지 않는다.

67. Dependency Security

67.1 Third-Party Dependency

사용 Dependency를 지속적으로 추적한다.

67.2 Critical Vulnerability

Critical 취약점이 있는 Dependency는 정책에 따라 Build 또는 Deployment를 차단한다.

67.3 Abandoned Dependency

유지보수 중단 Package를 식별하고 대체 계획을 수립해야 한다.

68. Marketplace Publisher Security

68.1 Publisher Verification

Publisher Identity와 Signing Identity를 검증한다.

68.2 Account Compromise

Publisher 계정 탈취 시 Package Publish를 즉시 차단할 수 있어야 한다.

68.3 Signing Key Revocation

유출된 Signing Key를 폐기할 수 있어야 한다.

68.4 Package 재검증

Publisher 보안 사고 발생 시 기존 Package도 재검증 대상이 될 수 있다.

69. Denial-of-Service Protection

69.1 보호 대상

- API
- Model Gateway
- Runtime Queue
- Plugin Gateway
- Knowledge Retrieval
- Event Ingestion

69.2 통제

- Rate Limit
- Quota
- Request Size
- Concurrency Limit
- Circuit Breaker
- Queue Backpressure

69.3 Tenant 공격

한 Tenant의 과도한 부하가 다른 Tenant에 영향을 주지 않도록 Fairness와 Quota를 적용한다.

70. Cost Abuse Security

AI 환경에서는 비용 소모 자체가 공격 수단이 될 수 있다.

70.1 통제 대상

- Model Token
- Child Agent
- Plugin Calls
- Workflow Loop
- Runtime Duration
- GPU Use

70.2 방어

- Cost Budget
- Iteration Limit
- Execution Limit
- Anomaly Detection
- Approval Threshold
- Kill Switch

70.3 Budget 우회

Child Execution 생성으로 Parent Budget을 우회하지 못하게 한다.

71. Autonomous Agent Abuse Protection

71.1 주요 위협

- 무한 반복
- Agent 간 연쇄 호출
- Tool 남용
- 대량 외부 요청
- Permission 탐색
- 비용 폭증

71.2 통제

- Maximum Iteration
- Maximum Delegation Depth
- Maximum Child Execution
- Tool Call Limit
- Cost Budget
- Time Limit
- Rate Limit

72. Human Approval Security

72.1 승인 무결성

Approval은 다음과 연결되어야 한다.

- Exact Action
- Exact Resource
- Execution
- Risk
- Expected Side Effect
- Expiration

72.2 승인 재사용 금지

다른 Action이나 변경된 Payload에 기존 승인을 재사용하지 않는다.

72.3 승인자 권한

승인자 자신도 해당 Action을 승인할 권한이 있는지 검증한다.

73. Security Policy Versioning

73.1 Policy Version

모든 중요한 Security Policy는 Version을 가진다.

73.2 Execution Snapshot

Execution 시작 시 적용된 Policy Version을 기록한다.

73.3 긴급 정책

보안상 긴급 Revocation은 기존 Snapshot보다 우선 적용할 수 있다.

73.4 변경 Audit

정책 변경 전후와 변경 주체를 기록한다.

74. Security Configuration

74.1 Configuration 유형

- Platform Security Baseline
- Environment Security
- Tenant Security
- Resource Security

74.2 우선순위

하위 설정이 상위 최소 보안 기준을 약화시킬 수 없어야 한다.

Platform Minimum

↓

Environment

↓
Tenant

↓
Resource

74.3 안전한 기본값

설정이 누락된 경우 가장 느슨한 값이 아니라 안전한 기본값을 적용한다.

75. Security Baseline

AGEX Platform은 최소 Security Baseline을 제공해야 한다.

예:

- TLS Required
- Default Deny
- Tenant Isolation Required
- Secret Store Required
- Audit Required for Privileged Action
- No Unlimited Runtime
- No Unverified Production Plugin
- No Plaintext Credential
- Signed Production Package

Tenant는 Baseline보다 강화할 수 있지만 약화할 수 없다.

76. Security Compliance Architecture

AGEX Core는 특정 법률에 종속된 고정 구현이 아니라 다양한 규정 준수 요구사항을 적용할 수 있는 구조를 제공해야 한다.

76.1 지원 구조

- Data Classification
- Retention
- Residency
- Audit
- Access Review
- Encryption
- Deletion
- Policy

76.2 규정 Package

특정 배포 환경에서는 Governance 또는 Policy Package 형태로 추가 요구사항을 적용할 수 있다.

77. Access Review

77.1 정기 검토

다음 권한을 정기적으로 검토할 수 있어야 한다.

- Administrator
- Service Identity
- Agent Permission
- Plugin Permission
- Secret Access

77.2 비활성 Identity

장기간 사용되지 않는 Identity를 탐지할 수 있다.

77.3 Excess Permission

실제 사용보다 과도한 Permission을 식별할 수 있다.

78. Security Observability

78.1 주요 Metric

- Authentication Failure
- Authorization Denial
- Policy Denial
- Cross-Tenant Attempt
- Secret Access
- High-Risk Action
- Sandbox Violation
- Malware Detection
- Package Block
- Security Incident

78.2 Dashboard

Platform과 Tenant 수준의 Security Dashboard를 분리할 수 있다.

78.3 Tenant Privacy

Platform Security Dashboard가 불필요하게 Tenant Content를 노출하지 않아야 한다.

79. Security Alerting

79.1 Alert 조건

- Critical Vulnerability
- Credential Leak
- Repeated Unauthorized Access
- Tenant Isolation Failure
- Runtime Escape
- Package Supply Chain Incident

- Unusual Data Export

79.2 Alert 대상

- Security Operator
- Platform Administrator
- Tenant Security Administrator
- Publisher

상황에 따라 대상이 달라질 수 있다.

80. Security Testing Strategy

AGEX는 최소 다음 Security Test를 수행해야 한다.

- Authentication Test
 - Authorization Test
 - Tenant Isolation Test
 - API Security Test
 - Prompt Injection Test
 - Agent Tool Abuse Test
 - Plugin Sandbox Test
 - Secret Leakage Test
 - SSRF Test
 - Webhook Replay Test
 - Supply Chain Test
 - Data Exfiltration Test
 - Privilege Escalation Test
 - DoS/Cost Abuse Test
-

81. Penetration Testing

81.1 대상

- Public API
- Console
- Plugin Runtime
- Marketplace
- Runtime Sandbox
- Authentication
- Tenant Boundary

81.2 시기

- Major Release
- 주요 Architecture 변경
- Security-sensitive 기능 추가
- 주기적 검증

81.3 결과

취약점은 Severity와 SLA 기준으로 추적한다.

82. Threat Modeling

82.1 적용 시점

새로운 주요 기능은 개발 전 Threat Modeling을 수행해야 한다.

82.2 대상 예

- New Agent Capability
- New Plugin Type
- Model Provider
- Marketplace Distribution

- Cross-System Integration
- New Data Store

82.3 Threat Model 산출물

- Asset
- Threat Actor
- Trust Boundary
- Attack Path
- Control
- Residual Risk

83. Security Risk Rating

Risk는 다음을 종합하여 평가할 수 있다.

- Data Sensitivity
- Permission
- Side Effect
- Network Access
- Autonomy
- Financial Impact
- Tenant Impact
- Recoverability

83.1 Risk Level

- Low
- Moderate
- High
- Critical

83.2 적용

Risk Level에 따라 승인, Sandbox, Audit, Quota 및 Monitoring 수준을 조정한다.

84. Security Exception

84.1 원칙

Security Baseline 예외는 코드나 설정에서 비공식적으로 우회하지 않는다.

84.2 Exception Resource

예외는 다음 정보를 포함해야 한다.

- Exception ID
- Scope
- Reason
- Owner
- Risk
- Approved By
- Expiration
- Compensating Controls

84.3 만료

Security Exception은 기본적으로 만료일을 가져야 한다.

84.4 영구 예외

영구 예외는 매우 제한적으로 허용한다.

85. Vulnerability Management

85.1 Source

- Dependency Scanner
- Container Scanner

- Code Scanner
- External Advisory
- Penetration Test
- Bug Report

85.2 처리

Detect

→ Validate

→ Severity

→ Impact Analysis

→ Fix

→ Test

→ Deploy

→ Verify

85.3 영향 분석

Package, Runtime Image 및 Tenant Installation까지 영향을 추적할 수 있어야 한다.

86. Security Patch

86.1 긴급 Patch

Critical 취약점은 일반 Release Cycle과 별도로 배포할 수 있다.

86.2 Compatibility

보안 Patch도 가능한 한 기존 Contract를 유지한다.

86.3 강제 Update

심각한 보안 위험이 있는 Package 또는 Runtime은 강제 차단 또는 Upgrade를 요구할 수 있다.

87. Disaster Recovery Security

87.1 Backup Credential

Backup과 복구 환경의 Credential도 별도 통제한다.

87.2 복구 후 검증

복구 과정에서 오래된 권한이나 폐기된 Credential이 되살아나지 않도록 검증한다.

87.3 Audit

복구 작업은 별도 Audit 대상이다.

88. Security Testing Acceptance Criteria

Security Architecture는 운영 전에 최소 다음을 충족해야 한다.

1. 모든 Human-Service Identity가 식별된다.
2. Tenant Context가 모든 주요 Resource에 적용된다.
3. Default Deny가 적용된다.
4. Agent가 자신의 Permission을 변경할 수 없다.
5. Runtime이 실행 전 Policy를 검증한다.
6. Plugin Credential이 Agent에 노출되지 않는다.
7. Secret Store가 분리되어 있다.
8. Tenant Isolation Test를 통과한다.
9. Cross-Tenant Retrieval이 차단된다.
10. Model Provider Data Policy가 적용된다.
11. Plugin Network Egress가 통제된다.
12. High-Risk Action에 Audit가 있다.
13. Critical Package를 긴급 Block할 수 있다.
14. Security Kill Switch가 존재한다.
15. Audit Record가 일반 수정 불가능하다.

16. Encryption at Rest와 in Transit이 적용된다.
 17. Production Package Integrity를 검증할 수 있다.
 18. Vulnerability Scan이 수행된다.
 19. Incident Response 절차가 존재한다.
 20. Security Monitoring이 제공된다.
-

89. Security Architecture 금지사항

다음 구조는 허용하지 않는다.

- 내부 Network라는 이유만으로 인증 생략
- Tenant ID 없는 Tenant Resource
- Default Allow 권한 모델
- 모든 Service가 하나의 관리자 Credential 공유
- Agent의 Permission 자체 변경
- Model 출력에 의한 직접 권한 승인
- Secret을 Prompt에 삽입
- Secret을 일반 Log에 기록
- Plugin의 임의 Network 접근
- Runtime Worker의 Core Database 직접 관리자 접근
- Sandbox 없이 외부 또는 생성 코드 실행
- Cross-Tenant Memory 또는 Knowledge 검색
- Permission 검증 전에 Retrieval Content를 Model에 전달
- Data Classification 확인 없이 외부 Model 사용
- 검증되지 않은 Marketplace Package의 Production 실행
- 서명되지 않은 Production Artifact
- Published Package Artifact 교체

- Audit 없는 Administrator Override
- 무제한 Agent Loop
- 무제한 Runtime 실행
- 무제한 외부 API 호출
- 보안 Policy를 Tenant가 Baseline 이하로 낮춤
- Critical Security Event를 Log만 남기고 통제하지 못하는 구조

90. Security Architecture 검증 기준

새로운 AGEX 기능은 다음 질문을 통과해야 한다.

1. 어떤 Asset을 보호해야 하는가.
2. 어떤 Identity가 접근하는가.
3. Trust Boundary가 어디인가.
4. Tenant Scope가 유지되는가.
5. 필요한 최소 Permission은 무엇인가.
6. Authentication이 필요한가.
7. Authorization이 어디서 집행되는가.
8. Policy가 어디서 평가되는가.
9. Data Classification은 무엇인가.
10. 외부 전송이 발생하는가.
11. Secret이 필요한가.
12. Sandbox 또는 격리가 필요한가.
13. Side Effect가 발생하는가.
14. Human Approval이 필요한가.
15. Audit 대상인가.
16. 취소 또는 Kill이 가능한가.

- 17. Security Event를 탐지할 수 있는가.
- 18. 공격 시 다른 Tenant로 확산되는가.
- 19. 공급망 위험이 존재하는가.
- 20. 실패 시 Fail Closed 되는가.

91. Security Architecture의 최종 정의

AGEX Security Architecture는 사용자, Service, Agent, Workflow, Plugin, Model, Data 및 Runtime을 기본적으로 신뢰하지 않고 모든 접근과 실행을 명시적인 Identity, Tenant, Permission, Policy, Classification 및 Security Context를 통해 통제하는 Zero Trust 기반 보안 구조이다.

AGEX에서 AI의 자율성은 보안 권한을 의미하지 않는다.

Agent와 Model은 계획하고 판단할 수 있지만 Permission, Policy, Credential, Tenant Boundary 및 Security Baseline을 변경할 수 없다.

모든 공식 실행은 Runtime을 통과하며 Runtime은 실행 직전에 Identity, Permission, Policy, Budget, Data Classification 및 Runtime Security Constraint를 다시 확인한다.

Plugin과 Marketplace Package는 외부 확장 코드이므로 Core와 격리하고, Manifest, Permission, Network, Signature, Dependency 및 Supply Chain을 검증해야 한다.

Knowledge와 Memory는 Model Context에 들어가기 전에 Tenant와 Permission을 검증하며, 외부 Content는 신뢰할 수 없는 데이터로 취급한다.

Model Provider는 동일한 신뢰 수준으로 취급하지 않으며 데이터 등급, 처리 지역, Provider 유형 및 Tenant Policy에 따라 Routing해야 한다.

Secret은 일반 Resource, Prompt, Memory, Event 또는 Log에 저장하지 않고 전용 Secret Management 계층을 통해 단기적이고 최소 범위로 제공한다.

모든 고위험 행위는 Audit 가능해야 하며 Critical Security Event 발생 시 Agent, Workflow, Plugin, Package, Provider, Runtime 또는 Tenant를 즉시 차단할 수 있어야 한다.

AGEX Security Architecture는 다음 문장으로 최종 정의한다.

AGEX Security Architecture는 AI가 무엇을 할 수 있는지를 능력으로 정의하되, 실제로 무엇을 해도 되는지는 Identity·Tenant·Permission·Policy·Data Classification·Runtime Security

가 끝까지 통제하는 Zero Trust 기반 AI Operating System 보안 체계이다.

본 문서는 AGEX 전체 제품의 Identity, 권한, Tenant 격리, 데이터, Runtime, AI, Extension, 공급망 및 운영 보안을 규정하는 공식 Security Architecture 문서로 사용한다.